

KI-basierte Bedrohungen und moderne Cybersicherheit: Eine formale Analyse von Angriffsmodellen und Verteidigungsmechanismen mit Fallstudie IT-Dienstleister Bechtle

Verfasser

September 4, 2026

Contents

1	Einführung	3
1.1	Problemstellung	3
1.2	Struktur und Beitrag der Arbeit	4
2	Formale Modellierung von KI-Angriffen	4
2.1	Klassische vs. KI-gesteuerte Angreifer	4
2.2	Klassifikation von Angriffsklassen	5
3	Formal-probabilistische Modelle für KI-Angreifer	6
3.1	Das Bernoulli-Lernmodell	6
3.2	Der KI-Lernzahlen-Satz	7
4	Redundanzsicherheit gegen KI-Angreifer	7
4.1	Multi-Kanal-Redundanzarchitektur	7
5	Dummy-Fragmentation gegen Modellbildung	9
5.1	Informationsverschleierung durch Decoys	9
6	Informationstheoretische Sicherheit	9
6.1	Äquivokation gegen Modellbildung	9
7	Praktische Fallstudie: Bechtle AG	10
7.1	Kontext: Bechtle als IT-Dienstleister	10
7.2	Bedrohungslandschaft für Bechtle	11
7.3	Empfohlene Architektur für Bechtle	11
7.4	Implementierungsempfehlungen für Bechtle	12
8	Diskussion: Grenzen und offene Fragen	13
8.1	Annahmen der Analyse	13
8.2	Offene Forschungsfragen	13

9	Zusammenfassung und Ausblick	13
9.1	Hauptbeiträge	13
9.2	Implikationen für die Praxis	14
9.3	Ausblick	14

1 Einführung

Die digitale Sicherheitslandschaft des Jahres 2026 wird von einer fundamentalen Verschiebung geprägt: Während traditionelle Cybersicherheit von der Annahme ausgeht, dass Angreifer *zufällige* oder *vorhersagbare* Fehler machen und nach bekannten Mustern agieren, stellt die Integration von Künstlicher Intelligenz (KI) in Angriffsszenarien ein qualitativ neues Risiko dar. KI-gesteuerte Angreifer sind *adaptiv*, *lernfähig* und können in Echtzeit Abwehrmaßnahmen umgehen, indem sie Angriffsmuster kontinuierlich optimieren.

Diese Arbeit entwickelt ein formales Modell zur Beschreibung und Analyse von KI-basierten Cyberangriffen. Dabei werden Konzepte aus drei vorangegangenen Arbeiten adaptiert und integriert:

1. Aus *Redundanzsicherheit* (redsec): Das Konzept, dass Verteidigungsmechanismen auf redundanten, unabhängigen Kanälen beruhen können und dass die Sicherheit quantifizierbar ist.
2. Aus *Fenster-Chiffre* (wchiffre): Das Konzept von Dummy-Elementen und gezielter Informationsverschleierung zur Blockierung adaptiver Angriffe.
3. Aus *Signatur-Chiffre* (sigchiffre): Das Konzept struktureller Mehrdeutigkeit und informationstheoretischer Sicherheit als Alternative zu klassischen Annahmen.

Im praktischen Kontext wird ein führender europäischer IT-Dienstleister – die Bechtle AG mit über 15.800 Mitarbeitern und 120 Standorten – als Fallstudie untersucht. Bechtle ist mit seinen dezentralen Geschäftsstrukturen, seinem Public-Sector-Geschäft (3.000 Mitarbeiter) und seiner Rolle als Integrator von Multi-Cloud-Strategien besonders exponiert gegenüber KI-gesteuerten Angriffen.

1.1 Problemstellung

Die zentrale Frage dieser Arbeit lautet:

Unter welchen Bedingungen können traditionelle Sicherheitsmodelle gegen adaptiv-intelligente Angreifer versagen, und welche formalen Bedingungen müssen Verteidigungsmechanismen erfüllen, um auch gegen solche Angreifer Garantien zu bieten?

Konkret wird gezeigt:

- Ein traditionelles Sicherheitsmodell (z. B. „Angreifer kennt den Algorithmus, aber nicht den Schlüssel“) versagt, wenn der Angreifer durch KI den Schlüssel *lernen* kann, ohne ihn direkt auszulesen.
- Ein Verteidigungsmechanismus, der gegen *statische* Angreifer robust ist, kann gegen *adaptive* KI-Angreifer völlig ineffektiv sein.
- Es gibt jedoch strukturelle Eigenschaften (Redundanz, Diversität, informationstheoretische Äquivokation), die auch gegen adaptive Angreifer formale Garantien bieten.

1.2 Struktur und Beitrag der Arbeit

Diese Arbeit gliedert sich in drei Teile:

Teil A (Formale Grundlagen): Definition eines neuen Sicherheitsmodells für KI-Angreifer (Abschnitte 2–3). Formale Definitionen von Angriffsklassen, Erfolgswahrscheinlichkeiten und Unabhängigkeit.

Teil B (Theoretische Analyse): Hauptresultate zu Bedingungen, unter denen Verteidigungsmechanismen gegen KI-Angreifer garantieren können (Abschnitte 4–6). Beweise von Sätzen über die minimale Redundanz, die erforderliche Diversität und informationstheoretische Grenzen.

Teil C (Praktische Anwendung): Fallstudie Bechtle (Abschnitt 7) mit konkreten Empfehlungen zur Modernisierung von Sicherheitsarchitekturen unter KI-Bedrohungen.

Die zentralen Beiträge sind:

1. Eine formale Taxonomie von KI-Angriffsklassen, die von statistischen Angreifern bis zu adaptiv-adversarialen Angreifern reicht (Definition 3).
2. Formale Bedingungen, unter denen KI-Lernzahlen Angriffserfolgswahrscheinlichkeiten bestimmen (Satz 1).
3. Beweis, dass Redundanz mit ausreichender Diversität gegen KI-Angreifer schützt, ähnlich wie gegen traditionelle Angreifer – aber mit stärkeren Anforderungen (Satz 2).
4. Algorithmen zur Berechnung minimaler Diversitätsgrade für IT-Dienstleister (Algorithmus ??).

2 Formale Modellierung von KI-Angriffen

2.1 Klassische vs. KI-gesteuerte Angreifer

Definition 1 (Statistischer Angreifer). Ein *statistischer Angreifer* $\mathcal{A}_{\text{stat}}$ ist ein probabilistischer Algorithmus, der:

1. Eine Menge von Eingaben $\{x_1, \dots, x_m\}$ und Ausgaben $\{y_1, \dots, y_m\}$ des Zielsystems beobachtet.
2. Eine *fest vor dem Angriff festgelegte* Strategie σ_{fix} verwendet, um auf diese Beobachtungen zu reagieren.
3. Einen erfolgreichen Angriff durchgeführt hat, wenn die Ausgabe des Algorithmus $\mathcal{A}_{\text{stat}}(x_1, \dots, x_m, y_1, \dots, y_m)$ ein geheimes Element s (z.B. einen Schlüssel) mit Wahrscheinlichkeit $p > \epsilon$ rekonstruiert.

Definition 2 (Adaptiver KI-Angreifer). Ein *adaptiver KI-Angreifer* $\mathcal{A}_{\text{KI}}$ ist ein Lernalgorithmus mit den folgenden Eigenschaften:

1. *Beobachtung:* Der Angreifer beobachtet während einer *Trainingsphase* T_{train} (Dauer: Sekunden bis Tage) eine Sequenz von Verhaltensstapeln (X, Y) des Zielsystems, wobei $X = \{x_1, \dots, x_n\}$ Eingaben und $Y = \{y_1, \dots, y_n\}$ Ausgaben sind.
2. *Modellbildung:* Der Angreifer trainiert ein Neuronales Netzwerk oder ein anderes Lernmodell M_{attack} mit dem Ziel, eine Funktion $f^* : X \rightarrow Y$ zu approximieren, die das Verhalten des Schutzmechanismus modelliert.

3. *Exploitierung*: Basierend auf dem trainierten Modell M_{attack} führt der Angreifer in der *Exploitierungsphase* gezielt Eingaben ein, die im ursprünglichen Sicherheitsmodell „verboten“ sind (z. B. Eingaben, die klassisch zu einem Alarm führen würden), aber die der Angreifer über sein Modell vorhersagen kann, dass sie undetektiert bleiben.
4. *Erfolg*: Der Angreifer hat einen erfolgreichen Angriff durchgeführt, wenn er nach k Exploitierungsschritten ein Ziel erreicht (z. B. Exfiltration von Daten, Ausfall des Systems) mit einer in voraus nicht bekannten, aber durch sein Lernmodell optimierten Wahrscheinlichkeit $p_{\text{KI}}(k)$, die größer als eine Sicherheitsschwelle ϵ ist.

Bemerkung 1. Der Unterschied zwischen Definition 1 und Definition 2 ist fundamental: Der statische Angreifer muss seine Strategie *vor* dem Angriff festlegen; er arbeitet nach einem vordefinierten Playbook. Der KI-Angreifer hingegen *lernt während des Trainings* die Schwächen des Systems und *passt seine Strategie in Echtzeit an* (während der Exploitierungsphase). Dies ist die zentrale Asymmetrie, die traditionelle Sicherheitsmodelle bricht.

2.2 Klassifikation von Angriffsklassen

Definition 3 (Angriffsklasse). Wir definieren eine Hierarchie von Angriffsklassen nach ihrer Adaptivität:

- **Klasse 1: Statische Mustererkennung.** Der Angreifer verfügt über bekannte Exploits (z. B. Heartbleed, ein spezifischer Buffer Overflow) und wendet diese stereotyp an. Die Erfolgswahrscheinlichkeit ist konstant über die Zeit.
- **Klasse 2: Schwache Adaptation.** Der Angreifer beobachtet die Reaktion des Systems auf Angriffe (z. B. ob eine Firewall blockiert) und passt *sein Timing* oder *seinen Zielort* an, nicht aber die Grundstrategie.
- **Klasse 3: Modellbasierte Adaptation.** Der Angreifer trainiert ein Lernmodell (z. B. ein neuronales Netzwerk) auf beobachteten (X, Y) -Paaren und erkundet den Eingaberaum gezielt, um Eingaben zu finden, die sein Modell als „sicher“ vorhersagt.
- **Klasse 4: Adversariale Adaptation.** Der Angreifer modelliert nicht nur das System, sondern auch den Verteidiger (z. B. ein Intrusion Detection System) und optimiert seine Angriffe *gegen beide* adversarial (z. B. durch Adversarial Perturbations).
- **Klasse 5: Multi-zyklische Lernoptimierung.** Der Angreifer durchläuft mehrere Zyklen von Reconnaissance, Exploitation, Observation und Model Retrain, wodurch sein Modell immer genauer wird.

In dieser Arbeit konzentrieren wir uns primär auf die Klassen 3 und 4.

Beispiel 1 (Real-world Szenario: Phishing mit KI). Ein klassischer statischer Angreifer (Klasse 1) würde Phishing-E-mails nach einem vordefinierten Schema schreiben. Ein KI-Angreifer (Klasse 3) würde hingegen:

1. Tausende bekannte erfolgreich-geklickte Phishing-E-mails sammeln.
2. Ein Sprachmodell (z. B. GPT oder ähnlich) auf diesem Datensatz trainieren.

3. Neue Phishing-E-mails generieren, die statistisch den erfolgreichen E-mails ähneln, aber neue Variationen sind.
4. Diverse Variationen testen und feststellen, welche Variationen durch Email-Filter blockiert werden.
5. Das Modell iterativ anpassen, um Filter zu umgehen.

Ein Klasse 4-Angreifer würde zusätzlich sein Modell gegen bekannte Phishing-Erkennungssysteme trainieren (adversarial training).

3 Formal-probabilistische Modelle für KI-Angreifer

3.1 Das Bernoulli-Lernmodell

Analogie zu Abschnitt 3 von redsec.tex: Dort wurde die Wahrscheinlichkeit $P_{\text{Safety}}(n, p)$ berechnet, dass ein System mit n redundanten Kanälen, von denen jeder mit Wahrscheinlichkeit p kompromittiert ist, dennoch mehrheitskorrekt funktioniert. Hier entwickeln wir ein analoges Modell für KI-Angreifer.

Definition 4 (Lernerfolgswahrscheinlichkeit). Gegeben sei:

- Ein Schutzmechanismus S (z. B. eine Firewall, eine Signatur-Erkennung, ein Intrusion Detection System).
- Eine Trainingsmenge T von Größe $|T| = m$ mit beobachteten Verhalten des Schutzmechanismus.
- Ein Lernalgorithmus $\mathcal{L}$ (z. B. ein neuronales Netzwerk), der eine Funktion $\hat{f} : X \rightarrow [0, 1]$ lernt, wobei $\hat{f}(x)$ die geschätzte Wahrscheinlichkeit ist, dass eine Eingabe x undetektiert bleibt.
- Der *echte* Verhalten $f^* : X \rightarrow \{0, 1\}$, wobei $f^*(x) = 1$ wenn x wirklich undetektiert bleibt, $f^*(x) = 0$ sonst.

Dann ist die *Lernerfolgswahrscheinlichkeit* auf einer neuen Test-Eingabemenge $\mathcal{T}_{\text{test}}$ definiert als:

$$\Pr_{\text{Lernfehler}} := \Pr_{x \sim \mathcal{T}_{\text{test}}} [\hat{f}(x) \neq f^*(x)] \quad (1)$$

Äquivalent: Die *Angriffserfolgswahrscheinlichkeit* ist:

$$p_{\text{KI}}(m) = \Pr_{\text{Angriffserfolg}} := \Pr_{x \sim \mathcal{T}_{\text{test}}} [\hat{f}(x) = 1 \text{ und } f^*(x) = 1] \quad (2)$$

Lemma 1 (Shattering und VC-Dimension). Für einen Lernalgorithmus $\mathcal{L}$ mit VC-Dimension d gilt nach der Theorie von Vapnik und Chervonenkis: Die Wahrscheinlichkeit eines Lernfehlers auf einer Test-Menge ist nach oben beschränkt durch:

$$\Pr_{\text{Lernfehler}} \leq O \left(\sqrt{\frac{d \ln(m)}{m}} + \sqrt{\frac{\ln(1/\delta)}{m}} \right) \quad (3)$$

mit Konfidenz $1 - \delta$.

Dies bedeutet: Um den Lernfehler unter eine Schwelle ϵ zu bringen, benötigt der Angreifer eine Trainingsmenge von Größe:

$$m \geq \Omega \left(\frac{d}{\epsilon^2} \right) \quad (4)$$

3.2 Der KI-Lernzahlen-Satz

Satz 1 (KI-Angriffserfolgswahrscheinlichkeit). Gegeben sei ein Schutzsystem S mit einer Menge von Exploitable-Eingaben $X_{\text{exploit}} \subseteq X$ (Eingaben, die das System kompromittieren würden, wenn sie nicht detektiert werden). Sei $|X_{\text{exploit}}| = k$ und $|X| = n$. Sei $\mathcal{L}$ ein Lernalgorithmus mit VC-Dimension d .

Für einen KI-Angreifer, der in der Trainingsphase m Beobachtungen des Schutzsystems macht, ist die Wahrscheinlichkeit, dass er in der Exploitierungsphase mindestens eine exploitable Eingabe erfolgreich durchschleusen kann, nach oben beschränkt durch:

$$\Pr[\text{Angriff erfolgreich}] \leq k \cdot \left(O \left(\sqrt{\frac{d \ln(m)}{m}} \right) + \exp(-m) \right) \quad (5)$$

Insbesondere: Falls $d \ll m^{1/2}$ (der Lernalgorithmus hat niedrige VC-Dimension), dann konvergiert die Angriffserfolgswahrscheinlichkeit gegen k/n mit exponentieller Rate in m .

Proof. Die Beweisidee basiert auf der Union Bound und VC-Theorie:

Schritt 1: Nach Lemma 1 ist die Wahrscheinlichkeit, dass das gelernte Modell $\hat{f}$ auf einer einzelnen Eingabe $x^* \in X_{\text{exploit}}$ einen Lernfehler macht, nach oben beschränkt.

Schritt 2: Es gibt k exploitable Eingaben. Nach der Union Bound ist die Wahrscheinlichkeit, dass der Angreifer mindestens eine davon erfolgreich durchschleusen kann, die Summe über alle:

$$\Pr[\text{Erfolg}] \leq \sum_{i=1}^k \Pr[\text{Fehler auf } x_i^*] \leq k \cdot O \left(\sqrt{\frac{d \ln(m)}{m}} \right) \quad (6)$$

Schritt 3: Für große m wird dieser Term exponentiell klein, sofern k nicht mit m wächst. $\square$

Korollar 1 (Minimale Trainingsmenge gegen KI-Angreifer). Um zu garantieren, dass ein KI-Angreifer mit Wahrscheinlichkeit mindestens $1 - \delta$ *nicht* mindestens eine exploitable Eingabe erfolgreich durchschleusen kann, benötigt das Schutzsystem eine Designkomplexität von mindestens:

$$m_{\min} = \Omega \left(\frac{d}{\delta^2} \cdot \ln(k) \right) \quad (7)$$

4 Redundanzsicherheit gegen KI-Angreifer

Diesen Abschnitt adaptieren wir aus dem redsec-Konzept, passen es aber auf KI-Angreifer an.

4.1 Multi-Kanal-Redundanzarchitektur

Definition 5 (Redundante Verteidigungsarchitektur). Eine *redundante Verteidigungsarchitektur* besteht aus:

- n unabhängigen Schutzkanälen $S_1, S_2, \dots, S_n$ (z. B. mehrere unterschiedliche Firewall-Hersteller, mehrere unterschiedliche Intrusion-Detection-Systeme, mehrere Sicherheitsanalysten).

- Eine Aggregationsfunktion (Voter) V , die die Ausgaben $y_1, y_2, \dots, y_n$ kombiniert zu einer Entscheidung:

$$\text{decision} = V(y_1, y_2, \dots, y_n) \quad (8)$$

Typischerweise: Majority Vote oder Unanimity.

- Unabhängigkeit: Die Wahrscheinlichkeit, dass der KI-Angreifer Kanal i erfolgreich „lernt“ und umgeht, ist stochastisch unabhängig von der Wahrscheinlichkeit für Kanal j (Annahme A1, analog zu redsec).

Definition 6 (Kanal-Kompromittierung durch KI). Ein Kanal S_i ist *kompromittiert* durch einen KI-Angreifer, wenn der Angreifer ein Lernmodell M_i trainiert hat, das den Verhalten von S_i mit ausreichender Genauigkeit nachbildet (z. B. Genauigkeit $> 90\%$), sodass der Angreifer Eingaben konstruieren kann, die S_i täuschen.

Die Wahrscheinlichkeit, dass Kanal i kompromittiert wird, sei p_i (abhängig von der VC-Dimension von S_i , der Größe der Trainingsmenge, der Diversität von S_i etc.).

Satz 2 (KI-Redundanzgarantie). Gegeben sei eine Redundanzarchitektur mit n Kanälen, von denen jeder mit Wahrscheinlichkeit p durch einen KI-Angreifer kompromittiert wird (Unabhängigkeitsannahme A1). Verwende einen Majority-Vote-Voter, der die Entscheidung trifft, dass ein Angriff blockiert wird, wenn mindestens $\lceil n/2 \rceil + 1$ der n Kanäle ein blockieren-Signal geben.

Dann ist die Wahrscheinlichkeit $P_{\text{KI-Robust}}(n, p)$, dass der Angreifer *nicht* erfolgreich ist (d. h., dass mindestens $\lceil n/2 \rceil + 1$ Kanäle unabhängig voneinander nicht kompromittiert wurden), gegeben durch:

$$P_{\text{KI-Robust}}(n, p) = \sum_{j=\lceil n/2 \rceil + 1}^n \binom{n}{j} (1-p)^j p^{n-j} \quad (9)$$

Insbesondere:

1. Für $n = 3$ und $p = 0.3$: $P_{\text{KI-Robust}}(3, 0.3) \approx 0.75$. Ein Angreifer mit 30% Erfolgsrate pro Kanal hat gegen eine Triple-Redundancy nur noch 25% Gesamterfolgsrate.
2. Mit wachsendem n konvergiert $P_{\text{KI-Robust}}(n, p) \rightarrow 1$ exponentiell schnell (bei festem $p < 0.5$), auch gegen adaptive KI-Angreifer.

Der Beweis ist identisch mit dem Beweis aus redsec.tex (Satz 3.2), angewendet auf KI-Angreifer statt Hardwarefehler. Die zentrale Erkenntnis ist, dass *unabhängige Kanäle* das gleiche mathematische Modell erfüllen, ob die Kompromittierung durch einen Random-Fehler (Safety) oder durch einen adaptiven KI-Angreifer (Security) hervorgerufen wird.

Bemerkung 2 (Kritische Bedingung: Unabhängigkeit der Kanäle). Der Satz hängt entscheidend davon ab, dass die Kanäle wirklich *unabhängig* sind. Wenn ein KI-Angreifer gegen mehrere Kanäle gleichzeitig optimiert, können diese Kanäle *korreliert* kompromittiert werden. Dies ist ein „Common-Cause-Angriff“ gegen Redundanz (analog zu Common-Cause-Failures in redsec). Die Unabhängigkeitsannahme wird durch *Diversität* erreicht:

- Unterschiedliche Hersteller (unterschiedliche Softwarebasis)
- Unterschiedliche Architekturen (z. B. Signatur-basiert vs. Anomalie-basiert)
- Unterschiedliche Konfigurationen und Parameter

5 Dummy-Fragmentation gegen Modellbildung

Diesen Abschnitt adaptieren wir aus dem wchiffre-Konzept (Fenster-Chiffre mit Dummy-Fragmentierung).

5.1 Informationsverschleierung durch Decoys

Definition 7 (Decoy-Architektur). Eine *Decoy-Architektur* (oder Honeypot-basierte Architektur) ist eine Technik, bei der das Schutzsystem absichtlich *falsche* oder *irreführende* Signale aussendet, um KI-Angreifer in ihrer Modellbildung zu stören.

Konkret:

- Das System gibt zu k -ten Mal ein echtes Sicherheitssignal aus (z. B. „blockierter Angriff“).
- Zu den $(k + 1)$ -ten bis $(k + d)$ -ten Mal gibt das System falsche Alarmer aus oder verhält sich unerwartet, um den Angreifer zu verwirren.
- Der Parameter d ist geheim und dem Angreifer unbekannt.

Dies ist analog zur Fenster-Chiffre (wchiffre), in der zu jedem k -ten Bit ein inhaltsloses Dummy-Bit eingefügt wird.

Satz 3 (Lernfehler unter Decoy-Rauschen). Gegeben sei ein Angreifer mit VC-Dimension d , der auf einer Menge von m Beobachtungen trainiert. Von diesen m Beobachtungen sind $(1 - \alpha)m$ echte Beobachtungen und αm sind Decoys (falsche/irreführende Signale), wobei α dem Angreifer unbekannt ist.

Dann ist der Lernfehler mindestens:

$$\Pr_{\text{Lernfehler}} \geq \alpha \tag{10}$$

Mit anderen Worten: Durch das Einschleusen von Decoys kann die Angriffserfolgswahrscheinlichkeit künstlich erhöht werden, völlig unabhängig vom Lernalgorithmus.

Beispiel 2 (Decoys gegen Phishing-Modellbildung). Ein KI-Angreifer trainiert sein Modell auf beobachteten Phishing-Sicherheits-Alerts. Das Schutzsystem sendet aber absichtlich zu jedem echten Alert zusätzlich 2 falsche Alerts aus. Der Angreifer kann nicht unterscheiden, welche Alerts echt sind. Sein Modell wird mit 33% Rauschen trainiert, wodurch sein Lernfehler explodiert.

6 Informationstheoretische Sicherheit

Inspiziert durch die Signatur-Chiffre (sigchiffre), die auf informationstheoretischer Sicherheit statt NP-Schwierigkeit basiert, entwickeln wir ein analoges Konzept für KI-Sicherheit.

6.1 Äquivokation gegen Modellbildung

Definition 8 (Informationstheoretische Äquivokation). Eine Schutzarchitektur hat *informationstheoretische Äquivokation* gegen einen KI-Angreifer, wenn:

1. Der Angreifer kann beliebig viele Beobachtungen sammeln.
2. Trotzdem gibt es zwei oder mehr *inkompatible Erklärungen* für diese Beobachtungen, die von den beobachteten Daten nicht unterschieden werden können.
3. Der Angreifer kann daher nicht eindeutig erkennen, welche der möglichen Funktionen f das System wirklich implementiert.

Formal: Seien $f_1, f_2 : X \rightarrow Y$ zwei mögliche Funktionen (Sicherheitsverhalten). Ein Angreifer wird als nicht in der Lage betrachtet, zwischen ihnen zu unterscheiden, wenn:

$$\forall (x_1, \dots, x_m) \in X^m : \Pr[f_1(x_i) = y_i] = \Pr[f_2(x_i) = y_i] \quad (11)$$

Satz 4 (Unverfälschte Äquivokation gegen KI). Wenn ein Schutzsystem mit parameterabhängiger Funktion f_θ implementiert ist, wobei der Parameter θ dem Angreifer *unbekannt* bleibt (z. B. ein Schlüssel), und wenn die Funktion f_θ so gewählt ist, dass zwei verschiedene Parameter $\theta_1 \neq \theta_2$ für den Angreifer nicht unterscheidbar sind (Äquivokation), dann ist die Sicherheit gegen einen KI-Angreifer *informationstheoretisch*:

Der Angreifer kann mit unbegrenzter Rechenkapazität und unbegrenztem Zugriff auf Trainingsdaten nicht erkennen, welcher der beiden Parametersätze verwendet wird.

Beispiel 3 (Multi-Cipher-Äquivokation). Ein System verschlüsselt alle seiner internen Signaturen mit AES, aber der Schlüssel wird täglich gewechselt und dem Angreifer nicht bekannt. Der Angreifer sieht nur die verschlüsselten Signaturen. Selbst wenn er beliebig lange trainiert, kann er nicht erkennen, welche Signaturen zu welchen Angriffen gehören. Dies ist informationstheoretische Äquivokation.

7 Praktische Fallstudie: Bechtle AG

7.1 Kontext: Bechtle als IT-Dienstleister

Die Bechtle AG ist ein führender europäischer IT-Dienstleister mit:

- 15.800+ Mitarbeitern
- 120+ Standorten in 14 europäischen Ländern
- 6,4 Mrd. EUR Jahresumsatz (2025)
- Drei Geschäftsbereiche: IT-Systemhaus, Managed Services, E-Commerce
- Starke Präsenz im öffentlichen Sektor (Public Sector: 3.000 MA)

Bechtle ist damit für KI-gesteuerte Angriffe besonders attraktiv:

1. **Dezentralität** = viele unabhängige Angriffsvektoren pro Land/Standort
2. **Public-Sector-Kunden** = kritische Infrastruktur (Bund, Länder, Schulen, Gesundheitswesen)
3. **Multi-Cloud-Strategie** = Komplexe Integrationspunkte für Angreifer
4. **Fachkräftemangel** = Sicherheit wird oft in großen Organisationen mit wenigen Experten gemanagt

7.2 Bedrohungslandschaft für Bechtle

Definition 9 (Bechtle-spezifische KI-Angriffsziele). Für Bechtle sind folgende Angriffsziele mit KI relevant:

- **Supply-Chain-Attacks:** Ein Angreifer infiziert Bechbles Distributions-Software oder Cloud-Services, sodass diese Malware an Tausende Kunden verbreiten (z. B. Echtzeit-Anomalieerkennung durch KI, um die beste Zeit zu finden).
- **Seitenkanalangriffe gegen Public-Sector-Kunden:** Ein Angreifer trainiert ein KI-Modell auf beobachteten Netzwerk-Verkehrsmustern von Behörden, um sensitive Daten zu exfiltrieren ohne direkt in die Systeme einzubrechen.
- **Soziale-Ingenieur-Attacken:** KI-generierte Phishing-E-mails an Bechtle-Mitarbeiter, personalisiert basierend auf LinkedIn- und andere Daten.
- **Floating-Point-Bit-Flip-Angriffe:** Ein Angreifer trainiert ein Modell, um vorherzusagen, wann und wo Gleitkomma-Berechnungen in Cloud-Systemen instabil werden, und triggert gezielt solche Instabilitäten.

7.3 Empfohlene Architektur für Bechtle

Basierend auf den Sätzen dieser Arbeit empfehlen wir eine fünfschichtige Verteidigungsarchitektur:

Algorithm 1 Redundante KI-resiliente Sicherheitsarchitektur für Bechtle

- 1: **Layer 1: Diverse Intrusion Detection**
 - 2: Deploye 3 unabhängige IDS-Systeme von verschiedenen Herstellern:
 - 3: - Suricata (signaturbasiert, OpenSource)
 - 4: - Zeek (verhaltenbasiert, Forschung)
 - 5: - Proprietary: Vendor XYZ (Black-Box AI-basiert)
 - 6: Aggregation: Majority Vote über alle 3 Systeme
 - 7: **Layer 2: Behavioral Anomaly Detection**
 - 8: Implementiere ein trainingbare Anomalieerkennung, die:
 - 9: - Jede User-Session baseline-lernt
 - 10: - Abweichungen vom Baseline mittels Isolation Forest erkennt
 - 11: - Parameter täglich wechselt (verhindert Lernen durch Angreifer)
 - 12: **Layer 3: Decoy-Injection**
 - 13: Injiziere absichtlich falsche Sicherheitsalarme:
 - 14: - Zu jedem echten Alert: 2 falsche Alerts
 - 15: - Falsche Alerts werden verschlüsselt in interne Logs geschrieben
 - 16: - KI-Angreifer können nicht unterscheiden, welche Alerts echt sind
 - 17: **Layer 4: Crypto-Agility**
 - 18: Implementiere mehrere Verschlüsselungsalgorithmen parallel:
 - 19: - Hauptkanal: AES-256
 - 20: - Parallel-Kanal: ChaCha20 (selbe Daten, anderes Verfahren)
 - 21: - Ein Angreifer, der AES-256 „bricht“, kann nicht automatisch ChaCha20 brechen
 - 22: **Layer 5: Human-in-the-Loop**
 - 23: Für verdächtige Ereignisse: Manuelles Review durch Sicherheitsanalysten
 - 24: Diese Analysten sind nicht-automatisierbar und widerstehen KI-Umgehung
-

Satz 5 (Gesamtrobustheit der Bechtle-Architektur). Gegeben sei die in Algorithmus 1 beschriebene Architektur. Angenommen:

- Die 3 IDS-Systeme in Layer 1 sind stochastisch unabhängig mit je $p_1 = 0.2$ Kompromittierungswahrscheinlichkeit.
- Layer 2 (Behavioral Anomaly) ist unabhängig von Layer 1 mit $p_2 = 0.3$.
- Layer 3 (Decoys) erhöht den Lernfehler um $\alpha = 0.33$.
- Layer 4 (Crypto-Agility) ist orthogonal (bindet die Angreifer an mehrere Anforderungen).
- Layer 5 (Human) ist letzte Verteidigungslinie mit $p_5 = 0.05$ (Menschen sind selten zu täuschen).

Dann ist die Gesamtwahrscheinlichkeit eines erfolgreichen Angriffs:

$$P_{\text{Angriff}} \leq p_1^3 \cdot p_2 \cdot e^{-\alpha m} \cdot \frac{1}{n_{\text{crypto}}} \cdot p_5 \quad (12)$$

Mit realistischen Zahlen ($m = 1000$ Trainingsbeobachtungen, $n_{\text{crypto}} = 2$ unabhängige Verschlüsselungen):

$$P_{\text{Angriff}} \leq 0.008 \cdot 0.3 \cdot e^{-330} \cdot 0.5 \cdot 0.05 \approx 10^{-145} \quad (13)$$

Dies ist eine praktisch unmögliche Erfolgswahrscheinlichkeit.

7.4 Implementierungsempfehlungen für Bechtle

1. Sofortmaßnahmen (Wochen):

- Deploye mindestens 2 unabhängige IDS-Systeme (Majority Vote statt Single Point of Failure).
- Implementiere Anomaly Detection mit täglichem Parameter-Rotation.

2. Mittelfristige Maßnahmen (Monate):

- Implementiere Decoy-Injection in allen Logging-Systemen.
- Etabliere Crypto-Agility für alle Verschlüsselungskanäle (mehrere Algorithmen parallel).
- Schulung der Sicherheitsanalysten auf adversariale Angriffserkennung.

3. Langfristige Strategie (Jahre):

- Entwicklung eines internen Bechtle-spezifischen KI-Modells, das Angreifer-KI überwacht und erkennt.
- Investition in Forschung zu informationstheoretischen Sicherheitsmetriken (analog Signatur-Chiffre).
- Aufbau einer „Purple Team“ (Offensive + Defensive Security), die die Architektur kontinuierlich adversarial testet.

8 Diskussion: Grenzen und offene Fragen

8.1 Annahmen der Analyse

Die bisherige Analyse basiert auf mehreren Annahmen, die in der Praxis verletzt sein können:

1. **Unabhängigkeit der Kanäle:** Wir nehmen an, dass KI-Angreifer die Kanäle unabhängig lernen. In der Realität können Seitenkanäle (z. B. Timing-Informationen) die Kanäle korrelieren.
2. **Statische Architektur:** Wir analysieren eine *feste* Architektur. Ein adaptiver Angreifer könnte die Architektur selbst erkennen und gezielt anpassen.
3. **Begrenzte Trainingsmenge:** Die Analyse in Satz 1 hängt davon ab, dass der Angreifer nur m Beobachtungen sammeln kann. Bei Supply-Chain-Attacks könnte m sehr groß sein.

8.2 Offene Forschungsfragen

1. Wie modelliert man Common-Cause-Angriffe gegen redundante Kanäle formal? (Erweiterung von Annahme A1)
2. Gibt es eine Theorie der *Crypto-Agility*, die beweist, dass parallele Verwendung mehrerer Verschlüsselungsalgorithmen gegen adaptive Angreifer schützt?
3. Wie können Decoys *adaptiv* eingesetzt werden, ohne dass Angreifer die Decoy-Rate selbst lernen?
4. Lässt sich Zero-Knowledge Proofs (aus sigchiffre) verwenden, um Sicherheitseverify ohne Informationspreisgabe zu erreichen?

9 Zusammenfassung und Ausblick

Diese Arbeit entwickelt ein formales mathematisches Modell für KI-gesteuerte Cyberangriffe und zeigt, unter welchen Bedingungen traditionelle Sicherheitsarchitekturen versagen und welche strukturellen Änderungen erforderlich sind.

9.1 Hauptbeiträge

1. **Taxonomie KI-basierter Angriffe** (Definition 3): Klassifikation von Angriffsklassen nach Adaptivität, von statischen Mustererkennung bis zu adversarialen KI-Angreifern.
2. **Formale Lernschränken** (Satz 1): Quantitative Bedingungen, unter denen KI-Angreifer garantiert scheitern.
3. **Redundanzgarantien** (Satz 2): Beweis, dass n -fache redundante Kanäle auch gegen KI-Angreifer robustheit bieten, mit expliziten Fehlerwahrscheinlichkeiten.
4. **Practical Defense Strategy** (Algorithmus 1): Fünfschichtige Architektur für IT-Dienstleister wie Bechtle mit exponentieller Reduktion der Angriffserfolgswahrscheinlichkeit.

9.2 Implikationen für die Praxis

Für IT-Dienstleister wie Bechtle ist die Aufgabe nicht, absolute Sicherheit zu erreichen, sondern die Angriffserfolgswahrscheinlichkeit unter eine Schwelle zu senken (z. B. $< 10^{-6}$ pro Jahr). Die in dieser Arbeit entwickelten Architekturen ermöglichen dies:

- Durch **Redundanz**: Mehrere unabhängige Verteidigungsschichten machen das System exponentiell robuster.
- Durch **Diversität**: Unterschiedliche Technologien verhindern Common-Cause-Angriffe.
- Durch **Verwirrung**: Decoys und Äquivokation erhöhen die Kosten für Angreifer exponentiell.
- Durch **Menschliche Intelligenz**: Human Review als letzte Verteidigungslinie gegen alle automatisierten Angriffe.

9.3 Ausblick

Zukünftige Arbeiten sollten untersuchen:

1. **Dynamische Redundanz**: Anstatt statischer Redundanzgrade, dynamisch variierende Architektur basierend auf erkannter Bedrohung.
2. **Quantenresistente Kryptographie + KI-Robustheit**: Wie kombinieren wir Schutz gegen zukünftige Quantencomputer mit Schutz gegen KI-Angreifer?
3. **Internationales Regelwerk**: Normung von KI-Sicherheitsanforderungen (ähnlich ISO 27001 für traditionelle Security).
4. **Zero-Trust mit KI-Agnostizität**: Sicherheitsarchitekturen, die weder dem vertrauenswürdigen System noch dem Angreifer-KI vertrauen.

References

- [1] Epp, S. (2026). *Redundanzsicherheit: Eine Vereinheitlichung von Funktionaler Sicherheit und Cyber Security*. Wissenschaftliche Arbeit.
- [2] Epp, S. (2026). *Modulares kryptografisches Verfahren mit Dummy-Fenster-Fragmentierung*. Wissenschaftliche Arbeit.
- [3] Epp, S. (2026). *Die Signatur-Chiffre: Eine strukturbasierte Verschlüsselungsmethode*. Wissenschaftliche Arbeit.
- [4] Vapnik, V., & Chervonenkis, A. (1971). *On the Uniform Convergence of Relative Frequencies of Events to Their Probabilities*. Theory of Probability & Its Applications, 16(2), 264-280.
- [5] Bitkom (2024). *Cyber-Angriffslandschaft 2024: Trends und Bedrohungen*.
- [6] National Institute of Standards and Technology (2015). *Cybersecurity Framework Version 1.1*.